TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Critical Rails Active Storage flaw allows file writes through crafted ImageMagick uploads

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-05	1.0 · 2026-11-05 12:03 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	No update
CVES	**ANALYST**	
None	Nick Sturgeon	

VULNERABILITY | CRITICAL | PATCH AVAILABLE; NO CONFIRMED EXPLOITATION REPORTED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

The Rails project disclosed GHSA-f3w6-w445-fwh9 on 2026-11-04, rated Critical at CVSS 3.0 9.8. An unauthenticated attacker may write arbitrary files on a server by getting a crafted file attached through Active Storage, the Rails upload component. If attachments use the Disk service, the attacker may also read any file the application process can read, which often includes secret_key_base and credentials for other systems. Rails says that can lead to remote code execution or lateral movement [S2]. The root cause is that Active Storage placed no limits on ImageMagick coders, and the analyzer runs at attach time, so no variant, preview or analyze call is needed [S1] [S2]. The fix commit says an uploaded SVG reached ImageMagick's MSL scripting coder, which reads and writes files named inside its script [S4].

An application is exposed only when three conditions all hold: it uses config.active_storage.variant_processor = :mini_magick (the default for load_defaults 6.1 or earlier), its ImageMagick policy does not deny the relevant coders (Rails says Debian and Ubuntu default policies do not), and it accepts uploads from untrusted users [S2]. Apps on the :vips default that arrived with load_defaults 7.0 are outside this path, although a separate libvips flaw, CVE-2026-66066, affected them in July [S1] [S14]. Fixes are in activestorage 8.1.4.1 and 8.0.5.2, part of a release that addresses 21 security issues. Older series are unsupported and get no fix, and security support for 8.0 itself ends on 2026-11-07 [S1] [S6]. A related advisory, GHSA-v924-7rp8-4mxh (High, CVSS 3.1 8.8), covers decoder selection through the uploaded file extension in FFmpeg and ImageMagick [S3].

No source we opened reports exploitation in the wild, a public proof of concept or a CVE ID as of 2026-11-04 and 2026-11-05 [S1] [S10] [S11] [S13]. The Rails announcement and CERT-FR make no statement either way [S6] [S8]. Rails notes that one attack chain was reported to it and does not assume it is the only one [S2]. No indicators of compromise have been published, and the advisory gives no method for checking whether an application was targeted [S1] [S11]. Absence of reports is not assurance: the comparable CVE-2026-66066 had third-party proof-of-concept code within about a day of disclosure and reported active exploitation about a month after the patch [S15] [S16].

What to do: find Rails applications that meet the three conditions and upgrade them to 8.1.4.1 or 8.0.5.2 with mini_magick 5.1 or later, then confirm the shipped policy actually loads [S1] [S2]. If you cannot upgrade, copy the shipped deny rules into the system policy; at minimum deny MSL, the Ghostscript coders and the gs delegate [S2]. Patching does not undo a past file read, so in-scope Disk service applications must rotate secret_key_base and every other secret the process can read, without keeping old secrets as a fallback [S1] [S2]. Applications on Rails older than 8.0 need the workaround now and a funded migration plan, and those on 8.0 should plan to move to a supported series [S1] [S6].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE

Public proof-of-concept code or a detailed technical walkthrough for GHSA-f3w6-w445-fwh9 will appear by 2026-12-05. The fix commit already names the SVG-to-MSL path, and the July Active Storage flaw was reverse-engineered within about a day. [S4] [S15] [S16]

LIKELY · MODERATE CONFIDENCE

Exploitation of this flaw against internet-facing Rails applications will be publicly reported by 2027-01-05. CVE-2026-66066 followed this pattern about a month after its patch, and the theft of secret_key_base and cloud credentials gives attackers a clear payoff. [S2] [S16] [S17]

LIKELY · LOW CONFIDENCE

The exposed population will be smaller than for CVE-2026-66066, because :mini_magick stopped being the default at load_defaults 7.0, but it will skew toward older applications that are harder to patch. Rails published no count for this flaw, and it told reporters in July that it had no telemetry on comparable exposure. [S1] [S2] [S15]

VERY LIKELY · MODERATE CONFIDENCE

Organizations running in-scope applications will not be able to rule out earlier abuse from logs alone. Rails has published no indicators or check, and a failed attempt may leave no trace, so secret rotation will remain the practical default for Disk service applications. [S1] [S2] [S11]

ALMOST CERTAIN · MODERATE CONFIDENCE

Some applications on Rails 7.2 or older, including distribution-packaged Rails, will stay on the policy workaround rather than a fixed upstream release through the end of 2026. Rails ships no fix for those series, and Debian listed all its releases as vulnerable with no fixed version on 2026-11-05. [S1] [S6] [S9]

INDICATORS OF COMPROMISE

No source publishes atomic indicators such as IPs, domains or malicious file hashes for this flaw, and Rails offers no compromise check [S1] [S11]. The entries below are behavioral and exposure markers: reported items come from the 2026-11-04 advisories and fix commit, derived items are analyst inferences, and none should be used as a blocklist without testing.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`ImageMagick MSL coder invoked while processing an upload`	The scripting coder in the reported chain. It reads and writes files named inside the image. Any MSL activity on a Rails upload path deserves review.	REPORTED	2026-11-04	[S2] [S4]
other	`Untrusted SVG upload reaching ImageMagick at attach time`	The fix commit says an uploaded SVG reached MSL through the analyzer at attach time. Rails does not say SVG is the only possible carrier.	REPORTED	2026-11-04	[S2] [S4]
other	`Upload content types: SVG, MSL, PostScript, PDF from untrusted users`	Review marker offered by one secondary source as its own advice, not by Rails. Declared content type is attacker-influenced, so a benign declared type does not clear a file.	REPORTED	2026-11-04	[S12]
filename	`*.avs`	GHSA-v924-7rp8-4mxh. An FFmpeg build with AviSynth support evaluates an uploaded .avs file as a script, which could disclose files or load an uploaded native library.	REPORTED	2026-11-04	[S3]
other	`text:@/etc/passwd`	Example of the @filename indirect read named in the shipped policy, which denies the path pattern @*. Treat this and similar strings as a content marker in uploaded image files.	REPORTED	2026-11-04	[S4] [S5]
filepath	`config/credentials.yml.enc`	Named by Rails as a secret store to treat as exposed, together with the master key. Reads of it or its key by an image tool process would be highly suspicious.	REPORTED	2026-11-04	[S1] [S2]
other	`secret_key_base`	Primary read target named by Rails. Exposure can enable remote code execution or lateral movement. Watch for its value in unexpected files or responses.	REPORTED	2026-11-04	[S2]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`gs delegate and Ghostscript-backed coders: PS, PS2, PS3, EPS, EPS2, EPS3, EPI, EPSF, EPSI, EPT, EPT2, EPT3, PDF, AI, EPDF, PDFA, POCKETMOD, XPS, PCL`	Coders and delegate Rails tells operators to deny in the workaround. Their use on an upload path that should handle only web images is worth reviewing.	REPORTED	2026-11-04	[S2] [S5]
other	`FFmpeg build option --enable-avisynth`	Exposure marker for the AviSynth path in GHSA-v924-7rp8-4mxh, which also needs the AviSynthPlus runtime. Rails says common Linux and Homebrew packages do not enable it, but ffmpeg.org GPL Windows and Linux builds do.	REPORTED	2026-11-04	[S3]
filepath	`/etc/ImageMagick-7/policy.xml`	Example system policy location given by Rails. Monitoring it for unexpected change is our inference: an arbitrary file write could in principle weaken controls if the process has write access. Normally it should not.	REPORTED	2026-11-04	[S2]
http-request	`POST /rails/active_storage/direct_uploads`	Derived from the Rails route file, which draws /direct_uploads under the Active Storage routes prefix; the prefix shown is the framework default and may be customized. Rails does not name this route in the advisory, and attach still has to happen. A secondary report says the same endpoint was the entry point for CVE-2026-66066 and needs no authentication.	DERIVED		[S20] [S17]
other	`msl:`	Derived from ImageMagick's coder:filename syntax, as shown by the text:@ example in the commit, and from the MSL denial. Possible content marker inside uploaded SVG or other image files. Rails has not published the exact payload, so absence of this string proves nothing, and encoding can hide it.	DERIVED		[S4] [S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`ephemeral:`	Derived from the shipped policy's denial of the EPHEMERAL coder, described as acting on or deleting other files. Possible content marker with the same limits as msl:.	DERIVED		[S4] [S5]
command	`identify, convert, magick or mogrify spawning gs, sh, bash, curl or wget`	Derived from the fact that the analyzer runs ImageMagick through MiniMagick on attach and from the gs delegate denial. Look on web hosts and on background job workers, since either may run analysis.	DERIVED		[S2] [S5]
command	`ffmpeg or ffprobe with an input path ending in .avs`	Derived from GHSA-v924-7rp8-4mxh, which says tempfiles kept the uploaded extension and were passed to these tools.	DERIVED		[S3]
filepath	`<Rails.root>/storage/`	Derived from the guide's example Disk service root, which may differ per application. Crafted uploads would persist here, so inspect SVG and other unusual types stored around the exposure window.	DERIVED		[S21] [S2]
filepath	`<Rails.root>/public/`	Derived from advice to look for files the application user did not create, especially in web-served paths. A public file write is the simplest route to later retrieval or a web shell. Rails has not reported this behavior.	DERIVED		[S11] [S2]
filename	`Unexpected *.rb, *.sh or *.php files in upload directories`	Derived by analogy. A lower-grade secondary source reports these for CVE-2026-66066 campaigns, not for this flaw. Useful because this flaw grants direct file write.	DERIVED		[S17] [S2]
other	`ImageMagick error: not allowed by the security policy`	Derived from ImageMagick documentation of the error raised when a policy denies a coder. After patching or the workaround, this text in application or job logs may mark a blocked attempt. It may also come from legitimate PDF or PostScript handling.	DERIVED		[S22] [S5]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

An attacker submits a crafted file to an application that attaches untrusted uploads through Active Storage with the :mini_magick processor. On attach, the ImageMagick analyzer runs without coder restrictions, and ImageMagick chooses a coder from the file's content. In the one reported chain, an SVG reaches the MSL scripting coder, which can read and write files named in its script [S2] [S4]. The result is arbitrary file write, plus file read on the Disk service. Secrets taken from readable files may then enable remote code execution or lateral movement [S2]. The exact payload is unpublished in the sources we reviewed. In the related GHSA-v924-7rp8-4mxh, the attacker controls the filename and declared content type, so the extension kept on the tempfile can steer FFmpeg or ImageMagick to a chosen decoder; with AviSynth this can disclose files or load an uploaded native library [S3]. The post-exploitation techniques below are possibilities from the stated impact, not observed activity.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Crafted file uploaded to an internet-facing Rails application; attaching it triggers the ImageMagick analyzer. Reported chain, no observed use. [S2] [S4]	Review upload requests from unauthenticated or newly registered users, particularly SVG, and correlate them with image tool activity.
Defense Evasion	T1036.008 Masquerading: Masquerade File Type	Attacker chooses the filename and declared content type so a decoder is selected by extension, as in GHSA-v924-7rp8-4mxh; ImageMagick also selects coders from content rather than the declared type. [S2] [S3]	Compare file magic bytes, extension and declared content type on stored uploads, and flag mismatches.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	With the Disk service, reading files the process can reach, such as secret_key_base, the master key, credentials file contents, and storage, database and third-party credentials. Stated as possible impact. [S1] [S2]	Audit reads of credential and key files by identify, convert, magick, ffmpeg or ffprobe.
Collection	T1005 Data from Local System	Reading local files through the coder, or through a preview image under the AviSynth path. Stated as possible impact. [S2] [S3]	Inspect unusual variants, previews and Disk service blobs, and monitor process file access.

Tactic	Technique	Procedure observed	Detection opportunity
Persistence	T1505.003 Server Software Component: Web Shell	Analyst inference: an arbitrary file write could place a script or code file on the application host. Not described by Rails. [S2] [S11]	File integrity monitoring on application and public directories, and alerts on new code files created by image tools or the application user.
Credential Access	T1606.001 Forge Web Credentials: Web Cookies	Analyst inference: a stolen secret_key_base could be used to forge signed or encrypted session data. Rails notes that rotation invalidates sessions, signed and encrypted cookies, and signed global IDs. [S3] [S2]	Look for sessions without a matching login event, and for privileged activity from unfamiliar sources.
Execution	T1129 Shared Modules	Under GHSA-v924-7rp8-4mxh, an AviSynth script could load an attacker-uploaded native library, possibly giving code execution in the FFmpeg process. [S3]	Alert on ffmpeg or ffprobe loading libraries from temporary or upload paths.
Lateral Movement	T1078 Valid Accounts	Using stolen database, storage or third-party credentials against connected systems. Rails states lateral movement as a possible outcome; the technique mapping is our inference. [S2]	Review application service account use from unexpected sources across database, cloud storage and SaaS logs.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

ImageMagick tool spawning a shell, Ghostscript or downloader on Linux SIGMA

```
title: ImageMagick Tool Spawning Suspicious Child Process
status: experimental
logsource:
  category: process_creation
  product: linux
detection:
  selection:
    ParentImage|endswith:
      - '/identify'
      - '/convert'
      - '/magick'
      - '/mogrify'
    Image|endswith:
      - '/gs'
      - '/sh'
      - '/bash'
      - '/curl'
      - '/wget'
  condition: selection
level: high
falsepositives:
  - Applications that legitimately render PDF or PostScript through the gs delegate
```

Built from the reported coder and delegate behavior. Run on web hosts and job workers. Tune for applications that intentionally render PDF.

Files written by ImageMagick tools outside temporary paths `KQL`

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("identify", "convert", "magick", "mogrify")
| where ActionType in ("FileCreated", "FileModified")
| where not(FolderPath startswith "/tmp/" or FolderPath startswith "/var/tmp/")
| project Timestamp, DeviceName, FolderPath, FileName, InitiatingProcessCommandLine,
InitiatingProcessAccountName
| order by Timestamp desc
```

Requires Linux file telemetry from Defender for Endpoint on the hosts. The analyzer should have little reason to write elsewhere, but baseline first. A clean result does not rule out compromise.

Direct upload volume by source `SPLUNK SPL`

```
index=web http_method=POST uri_path="*/rails/active_storage/direct_uploads*"
| stats count values(status) as status values(http_user_agent) as user_agents earliest(_time) as first
latest(_time) as last by src_ip
| where count > 20
| sort - count
```

Hunting aid only. Adjust field names and the threshold, and add the application's own upload routes, because many apps attach through form uploads instead. It finds unusual volume, not exploitation.

MSL coder reference in an SVG upload body `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"LOCAL Possible ImageMagick MSL coder reference in SVG upload"; flow:established,to_server; http.request_body; content:"<svg"; nocase; content:"msl:"; nocase; distance:0; classtype:web-application-attack; sid:1000001; rev:1;)
```

Based on a derived content marker, not a published payload. Needs decrypted traffic and a request body inspection limit large enough for uploads. Encoding can evade it, so use it to hunt and not as a protective control.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Rails Active Storage (activestorage gem): arbitrary file write and read in image analysis, GHSA-f3w6-w445-fwh9	All versions below 8.0.5.2, and 8.1 below 8.1.4.1. Exposure also requires :mini_magick, a policy that does not deny the coders, and untrusted uploads.	8.1.4.1, 8.0.5.2 (with mini_magick 5.1 or later). No fix for series older than 8.0.	None assigned as of 2026-11-05	9.8 (CVSS 3.0)	N/A (no CVE ID)	No	N/A
Rails Active Storage (activestorage gem): file read and RCE in video previews, analysis and image processing, GHSA-v924-7rp8-4mxh	All versions below 8.0.5.2, and 8.1 below 8.1.4.1, with untrusted uploads and either video or audio analysis, video previews, or ImageMagick processing. AviSynth path also needs an AviSynth-enabled FFmpeg and the AviSynthPlus runtime.	8.1.4.1, 8.0.5.2. No fix for series older than 8.0.	None assigned as of 2026-11-05	8.8 (CVSS 3.1)	N/A (no CVE ID)	No	N/A
Related, separate flaw for context: Rails Active Storage with libvips, GHSA-xr9x-r78c-5hrm	Below 7.2.3.2; 8.0 below 8.0.5.1; 8.1 below 8.1.3.1. Apps using libvips with untrusted image uploads.	7.2.3.2, 8.0.5.1, 8.1.3.1 (with libvips 8.13 or later)	CVE-2026-66066	9.5 (CVSS 4.0)	0.30071 (98.2nd percentile, 2026-11-04)	No	N/A

Immediate (0–24 hours)

- Inventory Rails applications, including vendor products and internal tools. Check Gemfile.lock for activestorage and mini_magick versions, search config/ for variant_processor and load_defaults, and check config/storage.yml for the Disk service. `IT OPS` [S2] [S10] [S11]
- Upgrade to activestorage 8.1.4.1 or 8.0.5.2. Move :mini_magick apps to mini_magick 5.1 or later first, because older versions raise an exception at boot. Restart application servers and background workers afterward. Upgrade all Rails apps, even those out of scope for this flaw, because the release fixes 21 issues. `IT OPS` [S1] [S2] [S6] [S10]
- Where you cannot upgrade today, copy the rules from activestorage/lib/active_storage/image_magick/policy.xml into the system policy (for example /etc/ImageMagick-7/policy.xml). At minimum deny the MSL coder, the Ghostscript coders and the gs delegate. Pre-8.0 apps should use this workaround until migrated. `IT OPS` [S1] [S2]
- Verify the policy in effect with: bin/rails runner 'puts MiniMagick.identify { |i| i.list "policy" }'. On hosts, check with magick -list policy, or convert -list policy on ImageMagick 6. A denied coder shows rights None. `IT OPS` [S1] [S10] [S22]
- On in-scope applications, hunt for files the application user did not create, particularly in web-served paths, review stored uploads for suspicious SVG and other non-image content, and preserve web, application and job logs before they age out. A clean result does not prove the absence of compromise. `SOC` [S11] [S12]

Short term (1–7 days)

- For in-scope Disk service apps, rotate secret_key_base, the master key, credentials file contents, storage and database credentials, and third-party tokens, without keeping old secrets as a fallback. Plan this as its own deploy, because it signs users out and invalidates signed and encrypted cookies, signed global IDs and Active Storage URLs. Rotate at once if the hunt finds evidence of abuse. `IT OPS` [S1] [S2] [S3] [S10]
- Address GHSA-v924-7rp8-4mxh. Check FFmpeg for AviSynth, and where you cannot upgrade, remove VideoPreviewer from config.active_storage.previewers and VideoAnalyzer and AudioAnalyzer from config.active_storage.analyzers. If the AviSynth requirements were met, treat readable secrets as exposed. An FFmpeg build without AviSynth does not fix the ImageMagick extension issue. `IT OPS` [S3] [S13]
- Look for conditions that defeat the shipped policy: apps that replace MiniMagick.cli_env after boot, clear the environment through MiniMagick.cli_prefix, or install their own MiniMagick::Shell; a server rule allowing a coder, including pattern="*"; and GraphicsMagick. Apps with custom MiniMagick setups must carry the rules in the system policy, and GraphicsMagick does not read ImageMagick policies. `IT OPS` [S1] [S2]
- For apps that need PDF or PostScript rendering, re-allow the gs delegate and only the needed coders in the server policy, and record the business reason and risk owner. `IT OPS` [S1] [S2]
- Confirm that the July CVE-2026-66066 fix was applied to libvips apps and that secrets were rotated, because that flaw has been reported as actively exploited. Installing 8.1.4.1 or 8.0.5.2 does not clean up any earlier secret exposure. `SOC` [S12] [S14] [S16]
- Ask software and hosting vendors whether their Rails-based products use Active Storage with ImageMagick, and when they will ship fixes. Track distribution packages too; Debian listed bookworm, trixie, forky and sid as vulnerable with no fixed version on 2026-11-05. `IT OPS` [S9] [S10]

- Deploy the hunting queries in this report after tuning, and add file integrity monitoring on application directories and ImageMagick policy files for in-scope hosts. `SOC` [S2] [S11]

Long term

- Fund and schedule migration off unsupported Rails. Pre-8.0 apps receive no fixes, and 8.0 security support ends on 2026-11-07, so 8.0.5.2 is only a brief stop on the way to a supported series. `LEADERSHIP` [S1] [S6]
- Isolate upload processing in a low-privilege worker or container with no access to application secrets, a read-only code directory and restricted egress. This is our recommendation, derived from the stated impact of file write and secret read. `IT OPS` [S2]
- Move secrets out of paths the application process can read as plain files where practical, and use short-lived credentials for storage and databases so a stolen value has limited life. `IT OPS` [S2]
- Maintain an owned inventory of frameworks and image or media libraries in internet-facing applications. Three critical or high Active Storage media-processing issues in about four months show this component needs ongoing attention. `LEADERSHIP` [S2] [S3] [S14]

Workarounds & compensating controls

- If neither the upgrade nor the policy can be applied quickly, temporarily disable uploads from untrusted users on affected apps. All three exposure conditions must hold, so removing untrusted uploads closes the reported path. `LEADERSHIP` [S2]
- Consider rejecting SVG and other non-essential types at the edge and in the app, checking actual file bytes. This reduces but does not remove risk: Rails does not assume the reported chain is the only one, and ImageMagick selects coders from content rather than the declared type. `IT OPS` [S1] [S2]
- Where direct uploads are not used, consider disabling the route. The current Rails route file gates it on ActiveStorage.draw_direct_upload_route; confirm this setting exists in your version, and note that form uploads remain a path to attach. `IT OPS` [S20]
- Treat web application firewall rules as a temporary layer only. In the CVE-2026-66066 case, Akamai and the discoverer both stressed that a WAF does not replace patching, and we found no published vendor rule for this flaw. `SOC` [S16]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Critical Rails Flaw Lets Attackers Write Server Files via Crafted ImageMagick Uploads
Published 2026-11-04 · `B1` Usually reliable, confirmed by other sources
Briefing source. Its technical claims match the Rails advisories.

[S2] Rails project (GitHub): Possible arbitrary file write and read in Active Storage image analysis (GHSA-f3w6-w445-fwh9)
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory.

[S3] Rails project (GitHub): Possible arbitrary file read and remote code execution in Active Storage video previews, analysis and image processing (GHSA-v924-7rp8-4mxh)
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory for the related flaw.

[S4] Rails project (GitHub): Ship an ImageMagick security policy for every MiniMagick process (commit 468aa9a)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary fix commit and source of the SVG to MSL detail. The page shows no date; the commit date is as reported by S11.

[S5] Rails project (GitHub): activestorage/lib/active_storage/image_magick/policy.xml (8-1-stable)
Published · **A1** Completely reliable, confirmed by other sources
Primary. The 33 shipped deny rules.

[S6] Ruby on Rails blog: Rails Versions 8.0.5.2 and 8.1.4.1 have been released!
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary release announcement.

[S7] Rails Discussions: Rails security releases 8.0.5.2 and 8.1.4.1
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary security bulletin, including gem hashes.

[S8] CERT-FR: CERTFR-2026-AVI-1452: Multiple vulnerabilities in Ruby on Rails
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Government CERT notice. No statement on exploitation.

[S9] Debian Security Tracker: TEMP-0000000-33AFA7 (GHSA-f3w6-w445-fwh9)
Published · **A2** Completely reliable, probably true
Distribution status, viewed 2026-11-05. Temporary tracker name.

[S10] Atlas: Rails' November 2026 Active Storage File Write and Read: GHSA-f3w6-w445-fwh9
Published 2026-11-04 · **C2** Fairly reliable, probably true
Smaller outlet. Packaged policy findings are its own tests and are not independently verified.

[S11] Ostorlab: Rails Active Storage RCE, Fixed in 8.1.4.1 (GHSA-f3w6-w445-fwh9)
Published 2026-11-04 · **C2** Fairly reliable, probably true
Security vendor analysis. Source for detection guidance and commit timing.

[S12] Brandefense: Rails Active Storage ImageMagick Flaw
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Secondary. Review markers are its own advice, not Rails guidance.

[S13] HOL: Rails Active Storage upload bug (GHSA-f3w6-w445-fwh9): how to fix
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Secondary exposure checklist. The publication date is taken from the related HOL record.

[S14] Rails project (GitHub): Possible arbitrary file read and remote code execution in Active Storage variant processing (GHSA-xr9x-r78c-5hrm, CVE-2026-66066)
Published 2026-07-29 · **A1** Completely reliable, confirmed by other sources
Primary advisory for the related July flaw.

[S15] The Hacker News: Critical Rails flaw could let attackers read server files (CVE-2026-66066), URL slug critical-rails-flaw-could-let
Published 2026-07-29 · **B2** Usually reliable, probably true
Used for the precedent timeline only. Title is paraphrased from the fetched summary. Third-party PoC was not validated by the outlet.

[S16] Help Net Security: KindaRails2Shell threatens Ruby on Rails apps (CVE-2026-66066)
Published 2026-08-03 · **B2** Usually reliable, probably true
Updated 2026-08-31 with VulnCheck's report of active exploitation. Precedent only.

[S17] Falcon Internet: CVE-2026-66066 KindaRails2Shell: Rails Active Storage RCE, active exploitation
Published 2026-09-01 · **C3** Fairly reliable, possibly true
Secondary, primary reports not linked. Concerns the July flaw; used by analogy only.

[S18] CISA: Known Exploited Vulnerabilities Catalog (version 2026.11.04)
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Primary. Entries added 2026-05-15 through 2026-11-04 were checked for Rails, Active Storage, ImageMagick and CVE-2026-66066, and none matched.

[S19] FIRST: EPSS API result for CVE-2026-66066
Published 2026-11-04 · **A2** Completely reliable, probably true
Probability model output for the related CVE. Not applicable to the GHSA-only items.

[S20] Rails project (GitHub): activestorage/config/routes.rb (main)
Published · **A2** Completely reliable, probably true
Primary code, main branch; may differ from deployed versions. Basis for a derived indicator.

[S21] Rails Guides: Active Storage Overview (edge)
Published · **A2** Completely reliable, probably true
Primary documentation. Disk root path is an example configuration.

[S22] ImageMagick: Security Policy
Published · **A2** Completely reliable, probably true
Primary documentation on policy syntax, precedence and verification.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-07-29	Rails publishes the separate libvips flaw CVE-2026-66066 with fixes; third-party proof-of-concept code is reported by the next day's article update.	[S14] [S15]
2026-08-31	VulnCheck reports active exploitation of CVE-2026-66066.	[S16]
2026-09-12	The tempfile extension fix for GHSA-v924-7rp8-4mxh is authored, as reported by Ostorlab.	[S11]
2026-11-03	The ImageMagick policy fix is committed, as reported by Ostorlab. Some outlets also place the release late on 11-03 in US time zones.	[S10] [S11] [S13]
2026-11-04	Rails announces 8.0.5.2 and 8.1.4.1, fixing 21 issues, and publishes GHSA-f3w6-w445-fwh9 and GHSA-v924-7rp8-4mxh.	[S2] [S3] [S6]
2026-11-04	CERT-FR publishes CERTFR-2026-AVI-1452, and The Hacker News reports on the flaw.	[S1] [S8]
2026-11-05	Debian tracker shows supported and development releases as vulnerable with no fixed version.	[S9]
2026-11-07	Scheduled end of security support for the Rails 8.0 series.	[S1] [S6]

Relevance to Indianapolis, Indiana & managed clients

We found no reporting specific to Indianapolis or Indiana. Direct risk sits with organizations running Rails applications that accept outside uploads: resident and permit portals in local government, patient or document intake portals in healthcare, application and coursework systems in education, supplier and customer portals in manufacturing, and customer sites at small and mid-size businesses. The likeliest exposure is older or custom-built applications, since :mini_magick is the default only for load_defaults 6.1 or earlier, and those are often maintained by a past contractor or a small team that may not know Rails is involved. Managed IT service clients should ask two questions this week: does any web application or vendor product run on Rails, and who is responsible for patching it? Service providers should check client asset inventories for Rails and ImageMagick, and contact vendors where the client has no access to the code. For healthcare, government and education bodies, stolen database or storage credentials could reach regulated or sensitive data, so in-scope findings should go to the incident response and compliance contacts as well as to IT. Patch windows should also allow for a separate secret rotation deploy, which signs users out and can disrupt portals serving the public.

Intelligence gaps

- Exploitation status: no source confirms or rules out in-the-wild use. Watch Rails, CISA, VulnCheck and major threat intelligence vendors.
- No CVE IDs assigned, and neither GHSA appeared in the GitHub Advisory Database as of 2026-11-04, per Ostorlab [S11]. KEV and EPSS tracking must wait for a CVE. Direct requests to the global advisory pages for both IDs returned 404 on 2026-11-05.
- No public IOCs, payload details or compromise check. Rails published forensic tooling for CVE-2026-66066 [S15]; watch for an equivalent here.
- Number of exposed applications is unknown. We found no scan data or vendor count for :mini_magick deployments.
- Other attack chains: Rails does not assume the reported chain is the only one, and GHSA-v924-7rp8-4mxh says other extension-selected decoders may be reachable without AviSynth but names none [S2] [S3].
- Whether a direct upload alone can trigger the flaw is not stated. The advisory says attach triggers analysis, so an attacker may also need an application flow that attaches the blob.
- Whether authenticated-only uploads count in practice depends on who can register. The CVSS vector scores no privileges, while the conditions speak of untrusted users. Treat self-registration and customer accounts as untrusted.
- Distribution fixes: Debian lists no fixed version yet. Timing and approach for Debian and Ubuntu packages are unknown [S9] [S10].

Other notes

- Severity scoring differs across the related items: GHSA-f3w6-w445-fwh9 uses CVSS 3.0, GHSA-v924-7rp8-4mxh uses CVSS 3.1 with low privileges required, and CVE-2026-66066 uses CVSS 4.0. The numbers are not strictly comparable [S2] [S3] [S14].
- Debian and Ubuntu nuance: Rails says default policies do not deny the relevant coders. Atlas's own tests are more detailed, finding that Debian 12 denies URL fetches, @ indirection and PostScript, PDF and XPS coders but not MSL or gs, while Debian 13 and Ubuntu 24.04 deny URL fetches and @ indirection only. These tests

are not independently verified. Atlas also reports that full ruby Docker images include Debian's ImageMagick while -slim images do not [S2] [S10].

- ImageMagick policy precedence uses a last-matching-rule model, so rule order matters when editing policy.xml, and older versions before 7.1.1-16 use case-sensitive patterns, so use uppercase coder names [S22]. Rails warns that a server rule allowing a coder overrides its shipped block [S1].
- Known-good gem SHA-256 values from the Rails bulletin, for integrity checks only and not indicators of compromise: activestorage 8.0.5.2 is 556c548b9b0ae5ddc3ec4e5278c065cb48d0fa5ca93c1f2a020e484b8e4c1d44, and activestorage 8.1.4.1 is 0f4e2f114f3584723a80a2c089aacc6170e765a0b2c385c9782e26ed78f05c66 [S7].
- The release also fixes other issues worth reviewing, including a Strong Parameters bypass, IP spoofing in RemoteIp on 8.1, and denial of service in safe_constantize, all rated High [S6]. GHSA-3f4q-8x5m-76v8, a low-rated local file disclosure in video previews and analysis, is listed as a separate issue [S6].
- Source caution: the claim of mass attacks against CVE-2026-66066 comes from a lower-grade secondary source, and its details were not verified; only the VulnCheck report via Help Net Security is treated as solid for that precedent [S16] [S17]. The CISA KEV feed was reviewed through a tool that returned it in parts, so recheck it before relying on the negative result for any audit [S18].
- The report's EPSS value applies to CVE-2026-66066 only and comes from the FIRST API [S19]. Do not read it as a score for this flaw.

CTI-20261105-05 v1.0 · Generated 2026-11-05 12:03 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.